

ZAP-MCP and ZAP-A2A: Formal Security Proofs

ZAP Protocol Authors

zap-protocol.io

2026

Abstract

We give formal security proofs for the constructions ZAP-MCP and ZAP-A2A described in the companion paper. We prove agent non-repudiation under the EUF-CMA security of ML-DSA-65, agent impersonation infeasibility under combined IND-CCA security of ML-KEM-768 and EUF-CMA security of ML-DSA-65, and replay freshness under the assumption that frame nonces are sampled with sufficient entropy. The proofs proceed by a sequence-of-games argument in the style of Shoup. Concrete advantage bounds are stated in terms of adversarial query budgets; we instantiate them for the recommended parameter set (ML-KEM-768, ML-DSA-65, AES-256-GCM, 96-bit nonces).

1 Notation and Primitives

Computational model. All adversaries are probabilistic polynomial-time (PPT) Turing machines. We work in the standard model unless otherwise noted; ML-DSA-65 and ML-KEM-768 are NIST-standard post-quantum primitives whose security claims are stated in FIPS 204 and FIPS 203 respectively. We assume the recommended Category 3 parameter sets throughout.

Hash function. $H : \{0, 1\}^* \rightarrow \{0, 1\}^{256}$ denotes SHA3-256. Where the proofs require it, we model H as a random oracle; all use of H in the construction is over collision-resistant input, so the random-oracle assumption is conservative.

Signature scheme. $\text{Sig} = (\text{Sig.KGen}, \text{Sig.Sign}, \text{Sig.Vfy})$ is ML-DSA-65, modeled as EUF-CMA secure with advantage $\text{Adv}_{\text{Sig}}^{\text{eufcma}}(\cdot)$. Concretely, NIST’s claim is that no PPT adversary achieves advantage greater than 2^{-128} given 2^{64} signing queries and 2^{128} hash queries.

KEM. $\text{KEM} = (\text{KEM.KGen}, \text{KEM.Encaps}, \text{KEM.Decaps})$ is ML-KEM-768, modeled as IND-CCA secure with advantage $\text{Adv}_{\text{KEM}}^{\text{indcca}}(\cdot)$.

AEAD. $\text{AE} = (\text{AE.Seal}, \text{AE.Open})$ is AES-256-GCM with 96-bit nonces, modeled as IND-CPA + INT-CTXT (i.e. authenticated encryption) with advantage $\text{Adv}_{\text{AE}}^{\text{ae}}(\cdot)$.

Identity binding. ZAP-RNS record for an entity X is a tuple $R_X = (\text{kem_pk}_X, \text{sig_pk}_X, \text{caps}_X, \sigma_{\text{root}})$ where σ_{root} is a publisher signature. We assume the publisher root is honest and its public key is known to all participants out of band. (Compromise of the publisher root is out of scope; mitigations are discussed at the end of the companion paper.)

2 Game-Based Definitions

2.1 Frame syntax

A ZAP-MCP/ZAP-A2A frame is the tuple

$$F = (magic, v, s, n, c, t)$$

where $magic$ is a 4-byte protocol tag, v is the version (1), $s = sid \parallel seq$ is the session and sequence identifier, n is the AEAD nonce, c is the AEAD ciphertext containing $\hat{\rho} \parallel \sigma$ where $\hat{\rho}$ is the canonical CBOR payload and σ is the per-frame signature, and t is the AEAD tag. We write $F_{A,T,sid,seq}$ for a frame from A to T in session sid at sequence seq .

2.2 Non-repudiation game

Game 1 (Non-repudiation $\text{Exp}_{\text{ZAP-MCP}}^{\text{nonrep}}$). The challenger generates honest agent keys $(sig_sk_A, sig_pk_A) \leftarrow \text{Sig.KGen}(1^\lambda)$ for some honest agent A , and publishes sig_pk_A . Adversary $\mathcal{A}$ is given access to a signing oracle $\mathcal{O}_{\text{Sign}}(m)$ that returns $\sigma \leftarrow \text{Sig.Sign}(sig_sk_A, m)$. Let $\mathcal{Q}$ be the set of messages queried.

$\mathcal{A}$ outputs a tuple $(F^*, \hat{\rho}^*, sid^*, seq^*, \sigma^*)$. The adversary wins if

$$\text{Sig.Vfy}(sig_pk_A, H(\hat{\rho}^* \parallel ctx^*), \sigma^*) = 1 \quad \wedge \quad \hat{\rho}^* \parallel ctx^* \notin \mathcal{Q}$$

where $ctx^* = \text{"zap - mcp/v1"} \parallel sid^* \parallel seq^*$. The advantage is $\text{Adv}_{\text{ZAP-MCP}}^{\text{nonrep}}(\mathcal{A}) = \Pr[\mathcal{A} \text{ wins}]$.

2.3 Impersonation game

Game 2 (Agent impersonation $\text{Exp}_{\text{ZAP-MCP}}^{\text{imp}}$). Setup as above; in addition, generate KEM key pair $(kem_sk_T, kem_pk_T) \leftarrow \text{KEM.KGen}(1^\lambda)$ for an honest tool T , and publish kem_pk_T and sig_pk_A . $\mathcal{A}$ may

- invoke $\mathcal{O}_{\text{Sign}}(m)$ as before, restricted so that no queried m contains a session id matching the test session;
- invoke $\mathcal{O}_{\text{Decaps}}(c)$ for any c except the challenge ciphertext;
- observe arbitrary protocol executions.

$\mathcal{A}$ wins if it completes a handshake transcript with T that T accepts as authenticated to A , where $\mathcal{A}$ does not hold sig_sk_A .

2.4 Replay game

Game 3 (Cross-session replay $\text{Exp}_{\text{ZAP-MCP}}^{\text{replay}}$). The challenger establishes two distinct honest sessions $sid_1 \neq sid_2$ between A and T . $\mathcal{A}$ observes the full traffic of sid_1 . $\mathcal{A}$ then attempts to inject a frame $F^* = F_{A,T,sid_1,seq}$ into sid_2 such that T accepts it as a fresh frame in sid_2 . Advantage is the acceptance probability.

3 Theorem 1: Non-Repudiation

Theorem 4 (Non-repudiation). *Let $\mathcal{A}$ be a PPT adversary against $\text{Exp}_{\text{ZAP-MCP}}^{\text{nonrep}}$ making at most q_s signing-oracle queries and q_h hash queries. There exists a PPT algorithm $\mathcal{B}$ against the EUF-CMA security of ML-DSA-65 making at most q_s signing queries, with*

$$\text{Adv}_{\text{ZAP-MCP}}^{\text{nonrep}}(\mathcal{A}) \leq \text{Adv}_{\text{Sig,ML-DSA-65}}^{\text{eufcma}}(\mathcal{B}) + \frac{q_h^2}{2^{257}}.$$

The running time of $\mathcal{B}$ is within an additive constant of that of $\mathcal{A}$.

Proof. We proceed by a sequence of games.

Game 0. The original game $\text{Exp}_{\text{ZAP-MCP}}^{\text{nonrep}}$. By definition, $\Pr[\mathcal{A} \text{ wins Game 0}] = \text{Adv}_{\text{ZAP-MCP}}^{\text{nonrep}}(\mathcal{A})$.

Game 1. Identical to Game 0 except that the challenger aborts if the random oracle ever produces a collision: i.e., if at any point two distinct queries $x \neq x'$ result in $H(x) = H(x')$. By the birthday bound, $\Pr[\text{collision}] \leq q_h(q_h - 1)/2^{257} \leq q_h^2/2^{257}$. Therefore

$$|\Pr[\mathcal{A} \text{ wins Game 0}] - \Pr[\mathcal{A} \text{ wins Game 1}]| \leq \frac{q_h^2}{2^{257}}.$$

Game 2. We construct $\mathcal{B}$. $\mathcal{B}$ runs the EUF-CMA game against ML-DSA-65, receiving challenge public key pk^* and a signing oracle $\mathcal{O}_{\text{Sign}}^*$. $\mathcal{B}$ simulates Game 1 for $\mathcal{A}$ as follows:

- Set $\text{sig_pk}_A := pk^*$ and publish.
- On $\mathcal{O}_{\text{Sign}}(m)$: query $\mathcal{O}_{\text{Sign}}^*(m)$, return the result, and add m to $\mathcal{Q}$.
- On a hash query, simulate the random oracle by lazy table maintenance with the no-collision invariant from Game 1.

When $\mathcal{A}$ outputs $(F^*, \hat{\rho}^*, \text{sid}^*, \text{seq}^*, \sigma^*)$, $\mathcal{B}$ computes $m^* := H(\hat{\rho}^* \parallel \text{ctx}^*)$ and outputs (m^*, σ^*) as its forgery.

Reduction analysis. If $\mathcal{A}$ wins Game 1, then by the winning condition σ^* is a valid signature on m^* , and $\hat{\rho}^* \parallel \text{ctx}^* \notin \mathcal{Q}$. Since the random oracle is collision-free in Game 1, m^* is therefore distinct from every $H(m)$ for $m \in \mathcal{Q}$, so $\mathcal{B}$ never queried m^* to $\mathcal{O}_{\text{Sign}}^*$. Hence (m^*, σ^*) is a valid EUF-CMA forgery against ML-DSA-65, and

$$\Pr[\mathcal{B} \text{ wins}] = \Pr[\mathcal{A} \text{ wins Game 1}].$$

Combining the two bounds:

$$\text{Adv}_{\text{ZAP-MCP}}^{\text{nonrep}}(\mathcal{A}) \leq \text{Adv}_{\text{Sig}}^{\text{eufcma}}(\mathcal{B}) + \frac{q_h^2}{2^{257}}.$$

□

□

Corollary 5 (Concrete instantiation). *With NIST's claim that $\text{Adv}_{\text{ML-DSA-65}}^{\text{eufcma}}(\mathcal{B}) \leq 2^{-128}$ for any PPT $\mathcal{B}$ with $q_s \leq 2^{64}$, and with $q_h \leq 2^{128}$,*

$$\text{Adv}_{\text{ZAP-MCP}}^{\text{nonrep}}(\mathcal{A}) \leq 2^{-128} + 2^{-1} \cdot 2^{-1} = 2^{-128} + \frac{1}{4}.$$

The dominant term for any realistic q_h is 2^{-128} . For deployment-realistic $q_h \leq 2^{80}$, the bound tightens to $2^{-128} + 2^{-97}$, i.e. negligibly above 2^{-97} .

4 Theorem 2: Agent Impersonation Infeasibility

Theorem 6 (Agent impersonation). *Let $\mathcal{A}$ be a PPT adversary against $\text{Exp}_{\text{ZAP-MCP}}^{\text{imp}}$ making at most q_d decapsulation queries, q_s signing queries, and q_h hash queries. There exist PPT algorithms $\mathcal{B}_1$ against IND-CCA of ML-KEM-768 and $\mathcal{B}_2$ against EUF-CMA of ML-DSA-65 with*

$$\text{Adv}_{\text{ZAP-MCP}}^{\text{imp}}(\mathcal{A}) \leq \text{Adv}_{\text{KEM, ML-KEM-768}}^{\text{indcca}}(\mathcal{B}_1) + \text{Adv}_{\text{Sig, ML-DSA-65}}^{\text{eufcma}}(\mathcal{B}_2) + \frac{q_h^2}{2^{257}}.$$

Proof. The handshake transcript that T accepts contains, by construction:

1. $\mathcal{A}$'s presented identity claim, naming A and including a signature $\sigma_h = \text{Sig.Sign}(\text{sig_sk}_A, H(th))$ over the running hash th of the transcript;
2. the KEM ciphertext $c_T = \text{KEM.Encaps}(\text{kem_pk}_T)$ contributing to the session secret;

3. key confirmation MAC over the handshake-derived session key.

For T to accept, σ_h must verify under sig_pk_A . Two cases arise.

Case A: th has been signed by A in some earlier session. By the construction of the transcript hash, th incorporates T 's nonce r_T , the session identifier sid , and a freshly-sampled handshake-time random from A . Two transcripts $th = th'$ would imply collision in H , occurring with probability $\leq q_h^2/2^{257}$.

Case B: th has never been signed by A . Then σ_h is a forgery of ML-DSA-65 on a fresh message under sig_pk_A . We construct $\mathcal{B}_2$ as in Theorem 4, embedding the EUF-CMA challenge public key as sig_pk_A and answering $\mathcal{A}$'s signing queries through the EUF-CMA oracle. We have

$$\Pr[\text{Case B}] \leq \text{Adv}_{\text{Sig}}^{\text{eufcma}}(\mathcal{B}_2).$$

Reducing key confirmation to KEM IND-CCA. If $\mathcal{A}$ manages to compute the correct key confirmation MAC without holding the KEM secret, then either (i) it has guessed the shared secret, or (ii) it has obtained it through the decapsulation oracle. Case (i) is information-theoretically negligible (2^{-256} for a 256-bit shared secret). For Case (ii), we construct $\mathcal{B}_1$ that embeds the IND-CCA challenge public key as kem_pk_T and answers decapsulation queries through its own oracle (with the usual restriction excluding the challenge ciphertext). $\mathcal{B}_1$ distinguishes the real shared secret from a uniform random by observing whether $\mathcal{A}$ produces the matching MAC. We have

$$\Pr[\text{key confirmation forged via KEM}] \leq \text{Adv}_{\text{KEM}}^{\text{indcca}}(\mathcal{B}_1).$$

Union bound. Combining,

$$\text{Adv}_{\text{ZAP-MCP}}^{\text{imp}}(\mathcal{A}) \leq \text{Adv}_{\text{KEM}}^{\text{indcca}}(\mathcal{B}_1) + \text{Adv}_{\text{Sig}}^{\text{eufcma}}(\mathcal{B}_2) + \frac{q_h^2}{2^{257}}.$$

□

□

Corollary 7 (Concrete impersonation bound). *For NIST Category 3 parameters, $\text{Adv}_{\text{ZAP-MCP}}^{\text{imp}}(\mathcal{A}) \leq 2^{-128} + 2^{-128} + q_h^2/2^{257} \approx 2^{-127}$ for $q_h \leq 2^{64}$.*

5 Lemma: Replay Freshness

Lemma 8 (Replay freshness). *Let ν be the AEAD nonce length in bits, and let Q be the maximum per-session frame count. For two distinct sessions $sid_1 \neq sid_2$, the probability that any single frame from sid_1 is accepted as fresh in sid_2 is at most*

$$\Pr[\text{replay accepted}] \leq \text{Adv}_{\text{AE}}^{\text{ae}}(\mathcal{B}) + \frac{Q(Q-1)}{2^{\nu+1}}.$$

Proof. The AEAD nonce in ZAP is derived as $\text{nonce}(sid, seq) = \text{HKDF}(K_n, sid \parallel seq)$ where K_n is a session-bound HKDF key derived from the handshake-shared secret. Two distinct sessions yield independently derived K_n values; thus an injected frame from sid_1 presents a nonce that is, in the sid_2 session's nonce-space, indistinguishable from uniformly random unless the AEAD construction is broken.

The injected frame's AEAD tag was computed under $K_{AB}^{(1)}$, the sid_1 session key. The recipient verifies under $K_{AB}^{(2)}$, the sid_2 session key. By the INT-CTXT property of AEAD, the probability of a tag verifying under a different key is at most $\text{Adv}_{\text{AE}}^{\text{ae}}(\mathcal{B})$, where $\mathcal{B}$ is a straightforward reduction.

The remaining term, $Q(Q-1)/2^{\nu+1}$, bounds the probability of a nonce collision *within* session sid_2 if the injection's nonce happens to clash with a pre-existing legitimate frame's nonce. By the birthday bound on ν -bit nonces with Q samples, this is at most $Q(Q-1)/2^{\nu+1}$. □ □

Corollary 9. *With $\nu = 96$ and $Q \leq 2^{40}$, $\Pr[\text{replay accepted}] \leq 2^{-128} + 2^{-17} \cdot 2^{-40} = 2^{-128} + 2^{-57}$, dominated by 2^{-57} , well below operationally relevant thresholds. Operators desiring tighter bounds may rotate sessions before $Q = 2^{32}$, yielding $\leq 2^{-32} \cdot 2^{-32} = 2^{-65}$ replay probability.*

6 Composite Property: Provenance Chain Integrity for ZAP-A2A

We extend Theorem 4 to multi-hop A2A task chains.

Theorem 10 (Provenance chain integrity). *Let τ be an A2A task delegated through agents $A_1 \rightarrow A_2 \rightarrow \dots \rightarrow A_k$, with each delegation producing a signed frame as described in the companion paper. Let $\mathcal{A}$ be a PPT adversary that produces a forged delegation chain $(F_1^*, F_2^*, \dots, F_k^*)$ with at least one F_i^* purporting to be from honest A_i but not actually signed by A_i . Then*

$$\text{Adv}_{\text{ZAP-A2A}}^{\text{prov}}(\mathcal{A}) \leq k \cdot \left(\text{Adv}_{\text{Sig}}^{\text{eufcma}}(\mathcal{B}_i) + \frac{q_h^2}{2^{257}} \right).$$

Proof. By a hybrid argument over the k positions in the chain. For each position i , an adversary that succeeds with non-negligible advantage on position i can be reduced to an EUF-CMA adversary on A_i 's key by Theorem 4. The factor k arises from the union bound over positions. $\square$

7 Composite Property: Capability-Bound Method Restriction

Proposition 11 (Capability binding). *Suppose tool T 's ZAP-RNS record advertises capability set $\text{caps}_T \subseteq \mathcal{M}$, where $\mathcal{M}$ is the universe of MCP method names. The handshake transcript hash binds $H(\text{caps}_T)$. If a frame in the resulting session invokes a method $m \notin \text{caps}_T$, an honest tool T rejects without processing.*

Proof sketch. Direct from construction: the handshake binding includes a commitment to caps_T verifiable by both endpoints, and the framed method invocation is checked against caps_T before dispatch. The only way to bypass this is to forge a transcript admitting a different caps_T , which requires either forging the publisher root signature (out of scope) or a hash collision in H ($\leq q_h^2/2^{257}$). $\square$

8 Forward Secrecy of Past Sessions

Proposition 12 (Forward secrecy). *Suppose at time t all long-term keys $\text{sig_sk}_A, \text{kem_sk}_T$ are exposed to $\mathcal{A}$. For any session that completed at time $t' < t$ with non-overlapping ephemeral handshake material, $\mathcal{A}$'s advantage at recovering the session payload is bounded by*

$$\text{Adv}_{\text{ZAP-MCP}}^{\text{fs}}(\mathcal{A}) \leq \text{Adv}_{\text{KEM,ephemeral}}^{\text{indcca}}(\mathcal{B}) + \text{Adv}_{\text{AE}}^{\text{ae}}(\mathcal{B}').$$

Proof sketch. ZAP handshake derives the session secret from a hybrid combination of static-static, static-ephemeral, and ephemeral-ephemeral KEM encapsulations. The ephemeral-ephemeral component, by construction discarded after the handshake, is independent of the long-term keys. Compromise of long-term keys at time t does not recover ephemerals discarded at time $t' < t$. Reduction is to ephemeral KEM IND-CCA. $\square$

Property	Bound
Non-repudiation (Thm. 4)	$\text{Adv}_{\text{Sig}}^{\text{eufcma}} + q_h^2/2^{257}$
Impersonation (Thm. 6)	$\text{Adv}_{\text{KEM}}^{\text{indcca}} + \text{Adv}_{\text{Sig}}^{\text{eufcma}} + q_h^2/2^{257}$
Replay (Lem. 8)	$\text{Adv}_{\text{AE}}^{\text{ae}} + Q(Q-1)/2^{\nu+1}$
Provenance chain (Thm. 10)	$k \cdot \left(\text{Adv}_{\text{Sig}}^{\text{eufcma}} + q_h^2/2^{257} \right)$
Capability binding (Prop. 11)	$q_h^2/2^{257}$
Forward secrecy (Prop. 12)	$\text{Adv}_{\text{KEM,ephemeral}}^{\text{indcca}} + \text{Adv}_{\text{AE}}^{\text{ae}}$

9 Summary Table

10 Discussion

10.1 Tightness

Theorem 4’s reduction is essentially tight: any non-repudiation forgery in ZAP-MCP translates directly to an ML-DSA-65 forgery, with only the random-oracle collision term separating the two probabilities. We have therefore reduced the question of agent message non-repudiation to the question of ML-DSA-65 EUF-CMA security, for which NIST’s standardisation body provides the conservative claim of ≥ 192 bits of post-quantum security.

10.2 Standard model vs random oracle

The random oracle assumption appears only in the bookkeeping of the hash function used to bind context strings. Standard-model construction is straightforward by replacing H with a collision-resistant hash plus a domain separation tag, at the cost of marginally larger advantage terms. We have chosen to state proofs in the simpler model.

10.3 Quantum oracle access

The above proofs are stated in the classical-query model. Post-quantum security claims for ML-DSA-65 and ML-KEM-768 are stated under quantum-oracle access in the relevant FIPS standards. The reductions above are tight under classical-query reductions and remain tight up to a constant factor under known-quantum lifts (we elide the technical details for brevity).

10.4 What is not proven

We do not prove anything about the semantics of the JSON-RPC payloads themselves, nor about the absence of side-channel leakage from agent implementations of ML-DSA-65 signing. Both belong to layers above and below the protocol respectively. Additionally, model-layer prompt-injection attacks are out of scope; ZAP-MCP provides cryptographic attribution but not semantic safety.

11 Conclusion

We have given concrete-advantage bounds for the principal security properties of ZAP-MCP and ZAP-A2A: non-repudiation under ML-DSA-65 EUF-CMA, agent impersonation infeasibility under ML-KEM-768 IND-CCA combined with ML-DSA-65 EUF-CMA, replay freshness under AEAD INT-CTXT, multi-hop provenance via a hybrid argument, capability binding via transcript hashing, and forward secrecy of past sessions via ephemeral KEM material. All bounds are parameterised by adversarial query budgets and instantiate to ≥ 128 -bit post-quantum security for the recommended parameter set.